LEXICON AUTOMATA

Algorithmic Governance & Sovereign Architecture

STRATEGIC PLAN

Version 5.0

December 2025
Chicago, Illinois

Executive Summary

Lexicon Automata is a boutique technical consultancy providing ML security auditing and compliance validation for organizations deploying high-risk AI systems. We occupy a specific market position: the technical depth that governance consultants lack.

The Core Insight: Big Four firms have spent decades perfecting organizational transformation delivered through stakeholder management and executive alignment. They cannot write code. When their AI governance engagements require actual technical testing—adversarial attacks, fairness metrics, model extraction assessments—they either skip it, hire a subcontractor, or do it poorly. We are the subcontractor they should be calling.

The Product: spectrum-governance is an open-source ML security testing framework that wraps IBM's Adversarial Robustness Toolbox (ART), SHAP, MAPIE, and garak into a unified interface with regulatory compliance mapping. The core library is Apache 2.0 licensed. The regulatory knowledge layer—Law Packs containing thresholds, reason code mappings, and NIST AI RMF requirements—is proprietary and sold as subscriptions.

The Strategy: Open-source the mechanism (which competitors could replicate anyway). Monetize the intelligence (which requires our specific combination of technical and regulatory expertise). Build authority as the creator of the standard. Cultivate governance consultants as referral partners, not competitors.

The Economics: Three-tier service model ranging from $5k-15k forensic audits to $50k-80k remediation engagements to $100k+ bespoke model development. Law Pack subscriptions at $250-400/month create recurring revenue independent of consulting. Teaching income ($60k baseline) provides stability during launch. Settlement fund ($60-110k) provides 12-month runway.

Year 1 Projections: Conservative $144k, Base $276k, Optimistic $468k in consulting revenue, plus $12-36k in Law Pack subscription revenue.

1. Market Position

1.1 The Structural Gap

The AI governance market has a structural gap. On one side: governance consultants who can facilitate workshops, develop policies, and navigate organizational change. On the other side: ML engineers who can build models but lack regulatory expertise. In the middle: almost no one who can do both.

When the EU AI Act requires "robustness against adversarial manipulation" (Article 15), governance consultants don't know how to test for it. When CFPB requires adverse action notices that reflect "actual reasons" for credit decisions, they don't know how to validate SHAP attributions against notice templates. When Illinois HB 3773 prohibits using zip codes as proxies for protected classes, they don't know how to detect proxy correlations in model behavior.

This gap is structural, not accidental. The skills required—graduate-level statistics, ML engineering, regulatory interpretation—don't typically coexist. Governance consultants come from policy, law, or business backgrounds. Data scientists come from STEM backgrounds. The intersection is small.

1.2 Competitive Positioning

We are not competing with McKinsey. We are the person McKinsey calls when they need technical depth.

This positioning is defensible for three reasons:

1. **Technical capability is scarce.** Big Four firms cannot easily replicate adversarial testing expertise. They could hire ML engineers, but those engineers lack regulatory context. Training takes years.
2. **Referral economics work.** When a Deloitte partner can bring in Lexicon Automata for the technical piece, they keep the client relationship and expand their offering. We get deal flow without client acquisition cost.
3. **Higher margin per hour.** The partner who bills $800/hour for stakeholder facilitation draws from a deep pool of MBAs. The person who can implement adversarial testing against production ML models is much rarer. Scarcity commands premium.

1.3 Target Client Profile

Segment	Characteristics
Primary	Mid-market financial services ($100M-$2B revenue) with ML models in production. Regulatory pressure from OCC, CFPB, state insurance commissioners. Internal model risk teams too small or generalist to conduct specialized adversarial testing.
Secondary	Chicago-based law firms with employment or consumer finance practices needing technical support for algorithmic discrimination litigation or compliance advisory.
Tertiary	Governance consulting firms (Big Four, boutique) seeking technical subcontractor for AI governance engagements requiring actual testing rather than policy development alone.

2. The Product: spectrum-governance

2.1 Architecture Overview

spectrum-governance is a Python framework for ML security testing and compliance validation. It wraps battle-tested libraries (ART, SHAP, MAPIE, garak, Evidently) in a unified interface designed for regulatory audit workflows.

RGB Architecture:

Module	Function	Capabilities
spectrum.red	Adversarial Testing	Evasion attacks (HopSkipJump, ZOO, Boundary, Square), LLM probing (DAN, prompt injection), privacy attacks (membership inference, attribute inference), model extraction
spectrum.blue	Defensive Hardening	Uncertainty quantification (conformal prediction), explainability (SHAP + reason code mapping), drift detection (PSI, KL-divergence), disparate impact analysis (4/5ths rule, proxy detection)
spectrum.lens	Governance Infrastructure	RCIA audit logging, report generation (EU AI Act Annex IV, CFPB), NIST AI RMF compliance validation, policy-to-implementation enforcement, data lineage (OpenLineage)

2.2 Transparent Metrics Architecture

spectrum-governance rejects proprietary scoring in favor of transparent, auditable metrics. Every measurement comes directly from ART or equivalent validated libraries. The value we provide is not mathematical obfuscation but expert interpretation: mapping raw metrics to regulatory requirements and explaining what the numbers mean for compliance.

Design Principles:

- **Transparency:** Every metric is defined in terms a client's data science team can verify independently.
- **Traceability:** Every assessment traces back to specific raw measurements. No hidden aggregations.
- **Regulatory grounding:** Thresholds come from statutory requirements, regulatory guidance, or documented industry benchmarks—never from arbitrary choices.

Core Metrics (from ART):

- **attack_success_rate:** Fraction of samples where the attack successfully changed the prediction
- **empirical_robustness_l2:** Mean L_2 perturbation required for successful attacks
- **perturbation_min:** Smallest perturbation that achieved a flip (worst-case vulnerability)
- **feature_sensitivity:** Per-feature contribution to successful attacks
- **mia_auc:** Membership inference attack success (privacy leakage)
- **extraction_fidelity:** Surrogate model agreement rate (IP exposure)

2.3 NIST AI RMF Integration

spectrum.lens includes a compliance validation engine for the NIST AI Risk Management Framework (AI RMF 1.0). This engine does not provide governance consulting—it validates whether required artifacts exist, whether stated policies are technically enforced, and whether evidence of compliance activities is logged.

Key Capabilities:

- **Artifact validation:** Check for existence and structure of required documentation (model cards, risk assessments, policies)
- **Policy-to-implementation alignment:** Given a stated policy ("no model with ASR > 5%"), verify that deployed models actually meet the threshold
- **Evidence logging:** Prove that required activities occurred through immutable RCIA audit trails
- **Gap analysis:** Compare artifacts against RMF requirements and output structured gap reports for governance consultants
- **Staleness tracking:** Monitor evidence age and flag when re-validation is needed (adversarial testing every 90 days, policies annually)

Strategic significance: The RMF integration positions spectrum-governance as the technical validation layer for governance programs. Governance consultants use the gap analysis to guide remediation; internal compliance teams use ongoing monitoring; regulators receive auditable evidence. We capture value from the technical component without delivering organizational change management.

3. Open Source Strategy

3.1 The Strategic Logic

Open-source the mechanism. Monetize the intelligence.

The core library wraps existing open-source tools (ART, SHAP, MAPIE). Any competent engineering team could rebuild these wrappers in 3-6 months by reading the same documentation we read. The code is not our moat.

What we gain by open-sourcing:

1. **Distribution:** spectrum-governance on GitHub gets discovered by engineers searching for AI governance tools. Some work at companies that need audits. The repository becomes a lead generation engine.
2. **Credibility:** When prospects can inspect every attack implementation and metric computation, they cannot accuse us of black-box consulting.
3. **Authority:** The creator of the tool that everyone uses occupies a different market position than a consultant who uses tools others created.

3.2 What Stays Proprietary: Law Packs

Law Packs are the regulatory knowledge layer that translates technical measurements into compliance artifacts. They include:

- **Threshold definitions:** For each regulatory context, the specific metric thresholds with source citations, confidence levels, and applicability notes
- **Reason code libraries:** SHAP-to-disclosure mappings for CFPB adverse action notices, EEOC selection explanations, etc.
- **RMF requirement mappings:** Which technical controls provide evidence for which NIST subcategories
- **Regulatory update service:** When guidance changes, subscribers receive updated packs automatically

Initial Law Packs (Year 1):

Law Pack	Coverage	Price
CFPB Credit	ECOA, Reg B, adverse action notices, fair lending	$300/month
EEOC Employment	Title VII, ADA, 4/5ths rule, selection procedures	$300/month
EU AI Act High-Risk	Article 15 robustness, Annex IV documentation, conformity	$400/month

Bundle discount: All three packs for $800/month (20% discount).

3.3 The Conversion Funnel

The open-source strategy creates a natural conversion funnel:

Tier	User Profile	Value Exchange
Discoverer	ML engineer tasked with "making sure our model is compliant." Clones repo, runs basic tests.	Free. Contributes to GitHub engagement, spreads awareness.
Subscriber	Needs maintained thresholds, proper citations, reason code mappings. Runs internal audits quarterly.	$250-400/month. Recurring revenue, qualifies for consulting.
Audit Client	Faces regulatory inquiry, needs independent third-party assessment for board or examiner.	$5k-15k per engagement. High-touch, high-margin.
Remediation Client	Audit revealed problems. Needs technical expertise to fix them.	$30k-80k per engagement. Longer duration, deeper relationship.

The funnel is efficient because each tier qualifies the next. Subscribers have demonstrated budget authority and genuine need. Audit clients have demonstrated willingness to pay for external expertise. The free users who never convert are not a loss—they contribute to ecosystem growth and may move to organizations with larger budgets.

4. Service Tiers

Tier	Scope	Deliverables	Pricing
Tier 1 Forensic Algorithmic Audit	Point-in-time assessment of existing model. Adversarial testing, fairness analysis, explainability review.	30-50 page report with regulatory mapping, executive summary, technical appendix	$5,000 - $15,000 2-3 weeks
Tier 2 Sovereign Remediation	Fix problems identified in audit. Adversarial training, fairness constraints, air-gapped deployments.	Hardened model, validation documentation, ongoing monitoring setup	$30,000 - $80,000 6-12 weeks
Tier 3 High-Assurance Model Dev	Build compliant model from scratch. Compliance-by-design architecture, full documentation.	Production model, Annex IV Technical File, ongoing retainer	$100,000+ 3-6 months

Year 1 Pricing Adjustment: First three Tier 1 engagements offered at $2,500-4,000 (pilot pricing) in exchange for case study rights and testimonials. After three completed engagements with documented outcomes, move to full pricing.

5. Threshold Methodology

Every threshold in spectrum-governance must be defensible. When a client or regulator asks "why this number?" we must have a documented answer. The threshold methodology establishes how we define, document, and maintain regulatory thresholds.

5.1 Hierarchy of Sources

Thresholds derive from five source types, in descending order of authority:

1. **Statutory:** Explicit numbers in regulation. Rare for ML metrics. Example: BIPA's 36-month retention limit.
2. **Regulatory guidance:** From guidance documents, enforcement actions, official interpretations. Example: 4/5ths rule (29 CFR 1607).
3. **Academic:** From peer-reviewed research. Must cite paper, note context, acknowledge limitations.
4. **Industry benchmark:** From documented practice at leading organizations. Cite sources while respecting confidentiality.
5. **Expert judgment:** Used when no other source exists. Document reasoning explicitly, schedule frequent review.

5.2 Documentation Requirements

Every threshold in a Law Pack must include:

- Threshold ID, metric name, operator, and value
- Source type and specific citation with URL
- Date validated and validator identity
- Applicability (domains, risk levels, jurisdictions)
- Confidence level (high/medium/low)
- Notes on interpretation and limitations
- Review date for next validation

5.3 Maintenance Protocol

- **Regulatory monitoring:** Federal Register alerts, EUR-Lex tracking, state law services
- **Enforcement tracking:** Monitor CFPB, FTC, EEOC, EU authority enforcement actions
- **Academic monitoring:** Google Scholar alerts for key terms
- **Version control:** Semantic versioning; threshold changes increment MINOR version
- **Subscriber notification:** 30-day notice for changes affecting existing assessments

6. Financial Projections

6.1 Revenue Model

Revenue derives from three streams: consulting services, Law Pack subscriptions, and retainers.

6.2 Year 1 Scenarios

Revenue Line	Conservative	Base	Optimistic
Tier 1 Audits	6 × $8k = $48k	12 × $10k = $120k	18 × $12k = $216k
Tier 2 Remediation	2 × $40k = $80k	3 × $45k = $135k	4 × $55k = $220k
Tier 3 Development	0	0	0
Retainers	2 × $4k × 4mo = $16k	3 × $4k × 5mo = $60k	4 × $4k × 6mo = $96k
Consulting Subtotal	**$144,000**	**$315,000**	**$532,000**
Law Pack Subscriptions	4 × $300 × 10mo = $12k	8 × $300 × 10mo = $24k	12 × $300 × 10mo = $36k
Teaching Income	$60,000	$60,000	$60,000
TOTAL YEAR 1	**$216,000**	**$399,000**	**$628,000**

Note: Tier 3 engagements ($100k+) not projected for Year 1. These require established reputation and case studies. Target Year 2.

7. Risk Matrix

Risk	Impact	Mitigation
UPL Allegation	Cease and desist, professional liability, reputational damage	Explicit disclaimers in all materials; Technical Advisor positioning; legal counsel review of deliverables; approved language protocols
Audit Miss	Client faces regulatory action after our "clean" report; liability claim	Tech E&O insurance with AI coverage; temporal limitation caveats; liability caps in MSA; ongoing monitoring recommendations
Open Source Adoption	spectrum-governance fails to achieve critical mass; authority positioning doesn't work	Aggressive promotion; excellent documentation; fast response to issues; identify anchor users for testimonials
Big Four Competition	Major firm forks spectrum-governance and builds competing practice	Creator authority; Law Pack moat (requires our skill combination); cost structure advantage ($350/hr vs $600+/hr); their use validates methodology
Regulatory Obsolescence	AI regulation evolves faster than we can maintain Law Packs	Regulatory monitoring built into routine; Federal Register alerts; EUR-Lex tracking; quarterly threshold review cycle
Support Burden	Open source users consume all time answering GitHub issues	Clear documentation; FAQ; explicit boundaries (community = best-effort; paid support with subscriptions)

8. 90-Day Execution Plan

Weeks 1-2: Legal Foundation

1. File LLC in Illinois (single-member, elect S-corp when revenue justifies)
2. Execute IP assignment (personal → company for spectrum-governance)
3. Obtain Tech E&O insurance with AI/ML coverage ($1M minimum)
4. Open business bank account; set up accounting (QuickBooks)
5. Draft MSA, SOW, and NDA templates with legal counsel review

Weeks 3-4: Open Source Launch

1. Publish spectrum-governance v0.1.0 to GitHub (Apache 2.0)
2. Write comprehensive README with installation, quickstart, examples
3. Create documentation site (Read the Docs or similar)
4. Announce on LinkedIn, Twitter/X, relevant Slack/Discord communities
5. Target: 50 GitHub stars in first two weeks

Weeks 5-6: Outreach Preparation

- Identify 50 outreach targets (TSE/law school network, Chicago legal, fintech with EU exposure)
- Research each individually (10 minutes minimum per target)
- Draft personalized outreach templates
- Prepare 30-minute discovery call framework

Weeks 7-8: Active Outreach

- Send outreach messages (10/day, 5 days/week = 100 total)
- Follow up on non-responses (Day 3, Day 7)
- Conduct discovery calls with interested parties
- Track in CRM (even simple spreadsheet)

Weeks 9-10: Content & Authority

- Publish first major analytical piece (2,000-4,000 words)
- Topic: Recent enforcement action analyzed through spectrum-governance lens
- Distribute via LinkedIn, relevant newsletters, community forums

Weeks 11-12: Close First Engagement

- Convert warmest lead to signed engagement
- Accept pilot pricing ($2,500-4,000) in exchange for case study rights
- Execute flawlessly; overdeliver on first client
- Request testimonial upon successful completion

— End of Strategic Plan —

LEXICON AUTOMATA | Version 5.0 | December 2025